

DispoSP

Protection des données personnelles

Statut RGPD non validé

23 septembre 2026 • Dossier à instruire avec le DPO

L'utilisation de DispoSP avec de vraies données personnelles reste conditionnée à la validation du cadre de traitement. Ce préalable concerne aussi un pilote avec de vrais agents. Pour le projet, un avis écrit du DPO est attendu sur la base légale et les durées de conservation, ainsi que la vérification des accords de sous-traitance et de la notice d'information.

Le responsable du traitement demeure responsable de la conformité et de la décision de mise en service. Le DPO conseille et contrôle ; ce dossier ne vaut ni son accord ni une attestation de conformité. Les essais préparatoires doivent utiliser des données fictives.

1 Le traitement en une fiche

Rubrique	Éléments à confirmer
Responsable du traitement	SDIS concerné : identité exacte, représentant et service responsable à renseigner.
Finalité	Recueillir les disponibilités, préparer et publier les gardes et gérer les désistements.
Base légale proposée	Mission d'intérêt public, article 6 paragraphe 1 e. Le DPO doit vérifier le fondement juridique applicable et la nécessité des données collectées.
Personnes concernées	Sapeurs-pompiers professionnels et volontaires, gestionnaires et administrateurs concernés.
Destinataires	Agent et encadrement habilité selon leurs fonctions. Périmètre exact à documenter, notamment lors des transferts entre centres.
Validation attendue	Avis du DPO, décision du responsable du traitement, contrats applicables, durées arrêtées et notice finalisée.

Les quatre pièces prioritaires

Une décision documentée sur la base légale ; un tableau de conservation approuvé ; les DPA applicables à Supabase et Resend avec leurs preuves d'acceptation ; une notice complète remise aux agents.

L'hébergement et les autres prestataires doivent également être couverts.

2 Les données et les sous traitants

Catégorie	Données concernées
Identité et coordonnées	Nom, grade, fonction, matricule, email et téléphone.
Compétences et organisation	Qualifications et dates d'obtention, disponibilités, validations, affectations, gardes publiées et désistements.
Texte libre et traçabilité	Commentaires, motifs de désistement, auteur et date des actions, valeurs journalisées avant et après modification.
Données techniques	Abonnements Web Push, identifiants et clés associés, journaux d'authentification et métadonnées à inventorier selon la configuration.

Les commentaires et motifs peuvent contenir des données de santé ou relatives à des tiers. Le DPO doit arrêter leur nécessité et leur encadrement. Mesures proposées à combiner : consigne de ne pas saisir de motif médical, limitation du texte collecté et absence de motif détaillé dans les emails. La copie des motifs dans les messages doit être vérifiée sur la version déployée.

Contrats et flux à examiner

Prestataire ou service	Preuves attendues
Supabase	DPA applicable au compte, preuve d'acceptation, région du projet, sous-traitants ultérieurs, accès de support et garanties de transfert.
Resend	DPA applicable, preuve d'acceptation, contenu transmis, durées de rétention et garanties des transferts internationaux.
Hébergeur web	Identité contractuelle, DPA, régions de traitement et journaux. Le déploiement Vercel observé ne prouve pas à lui seul la configuration juridique de production.
Services Web Push	Cartographie des fournisseurs, métadonnées, rôle juridique et conditions applicables. Un contenu chiffré ne permet pas de conclure à l'absence de données personnelles.

Un DPA est un accord de traitement des données encadrant la sous-traitance. Il faut vérifier comment il devient opposable au titulaire du compte, et conserver la version applicable ainsi que la preuve d'acceptation ou de signature. La présence d'un DPA public ne démontre pas cette acceptation.

Une région européenne ne suffit pas à exclure tout transfert hors Espace économique européen : les accès distants et les sous-traitants ultérieurs doivent aussi être examinés. [1, 2, 3]

3 Les durées restent proposées

Les valeurs ci-dessous sont des hypothèses à soumettre au DPO et au responsable du traitement. Elles figurent dans le script local de purge, mais leur présence dans le code ne constitue pas une validation juridique. Chaque durée doit être justifiée par la finalité et les obligations applicables. [4]

Données	Proposition	Décision attendue
Campagnes et données liées	24 mois après la fin de campagne	Justifier le besoin opérationnel et statistique. Distinguer les pièces nécessaires aux RH, à l'indemnisation ou aux archives.
Journal des actions	12 mois	Justifier la durée et les données conservées pour la sécurité et la traçabilité.
Notifications et envois associés	6 mois	Définir l'utilité, le point de départ et le sort des copies chez les destinataires.
Invitations	3 mois	Préciser le point de départ, y compris pour les invitations acceptées, expirées ou annulées.
Comptes et fiches	Durée du rattachement actif proposée	Organiser le départ ou le transfert. Séparer les données à supprimer de celles à conserver pour une obligation justifiée.

Distinguer conservation et suppression

La fin du besoin opérationnel ne permet pas nécessairement de supprimer toutes les pièces. Le service RH, le service des archives et le DPO doivent déterminer les éventuelles durées d'archivage intermédiaire, les accès restreints et les règles de sort final.

Les sauvegardes, journaux d'authentification, abonnements Web Push, exports téléchargés et emails conservés dans les messageries nécessitent des règles propres. La purge de la base applicative ne supprime pas automatiquement ces copies.

Mettre en œuvre la décision validée

Le script `purger-les-donnees-anciennes.sql` prévoit une exécution manuelle. La fréquence mensuelle est une proposition d'exploitation ; désigner un responsable, conserver une trace de chaque exécution et contrôler les échecs. Toute automatisation doit reprendre les durées effectivement approuvées.

Avant une suppression, vérifier le périmètre, les obligations de conservation et les sauvegardes. Prévoir également le traitement des données restaurées afin de ne pas réintroduire durablement des données déjà supprimées.

4 Les droits et la sécurité

Les demandes doivent être reçues par un canal identifié, instruites avec le DPO et exécutées par les personnes habilitées. Les scripts techniques facilitent certaines opérations ; ils ne déterminent ni la recevabilité d'une demande ni les exceptions légales.

Droit	Procédure à formaliser
Accès et rectification	Contrôler le périmètre de l'export avant remise par un canal adapté. Corriger les données inexactes et traiter les copies concernées.
Portabilité	Ne pas la promettre systématiquement. Elle ne s'applique pas au traitement fondé sur la mission d'intérêt public proposée ici. L'export peut néanmoins servir au droit d'accès. [5]
Effacement	Vérifier les obligations de conservation avant suppression. Contrôler les comptes, données liées, journaux, copies et sauvegardes.
Limitation et opposition	Instruire la demande et décider des traitements à suspendre ou à maintenir. La désactivation du compte seule ne limite pas les traitements des données déjà stockées.

Les outils présents dans le dépôt

Les scripts `exporter-les-donnees-d-un-compte.sql`, `retirer-un-compte.sql` et `purger-les-donnees-anciennes.sql` sont présents dans `supabase/provisioning`. Leur exécution sur la production et l'exhaustivité de leurs effets doivent être contrôlées avant de les utiliser pour répondre à une demande.

L'effacement de coordonnées dans un journal ne prouve pas une anonymisation irréversible : des identifiants, dates, liens ou événements peuvent permettre une réidentification. Les emails déjà remis et les copies téléchargées demandent un traitement distinct.

Les contrôles à documenter

- Vérifier les droits par rôle et par centre, y compris après désactivation, transfert et changement de compte sur un appareil.
- Vérifier les accès techniques, la protection des secrets, la configuration HTTPS et la visibilité des journaux.
- Documenter la sauvegarde, la restauration, les incidents et le circuit d'alerte au DPO.
- Évaluer avec le DPO la nécessité d'une analyse d'impact et conserver la justification de cette décision.

Aucune garantie absolue de cloisonnement, de suppression ou de conformité ne doit être déduite de la seule architecture. Ces contrôles doivent porter sur la version et la configuration effectivement mises en service.

5 La décision avant les données réelles

Le passage à des données personnelles réelles reste suspendu tant que le cadre de traitement et les pièces ci-dessous ne sont pas finalisés. Un essai avec de vrais agents est déjà un traitement de données personnelles.

Élément attendu	Responsable pressenti	Statut
Identifier le responsable du traitement et inscrire le traitement au registre.	Organisme avec le DPO	À documenter
Arrêter la base légale et son fondement juridique.	Responsable du traitement avec avis du DPO	À valider
Approuver les durées, les archives et les modalités de purge.	Métiers, archives et DPO	À valider
Vérifier les DPA Supabase et Resend et les preuves d'acceptation.	Organisme avec juridique et DPO	À fournir
Examiner l'hébergement, les services Web Push et les transferts.	Technique avec juridique et DPO	À vérifier
Arrêter le traitement des champs libres et des motifs dans les messages.	Métiers avec le DPO	À décider
Finaliser et remettre la notice aux agents.	Responsable du traitement	À finaliser
Organiser les droits, la purge, les incidents et les contrôles de sécurité.	Référents désignés	À documenter
Statuer sur la nécessité d'une analyse d'impact.	Responsable du traitement avec avis du DPO	À documenter

La trace de validation à conserver

Consigner la version du dossier examinée, les noms et fonctions des personnes consultées, l'avis daté du DPO, les réserves éventuelles et leur résolution. Joindre la décision du responsable du traitement et les références des contrats applicables.

Le présent dossier ne préjuge pas de ces décisions. Aucun contrat n'est accepté, aucune notice n'est diffusée et aucune suppression de données n'est exécutée par la préparation de ce document.

6 La notice destinée aux agents

Trame à compléter puis à valider avant diffusion

Les champs entre crochets sont nécessaires à la finalisation. Cette trame ne doit pas être remise en l'état aux agents. La notice devra rester accessible et être fournie au moment approprié de la collecte, y compris lorsque les données proviennent de l'encadrement. [6]

Qui utilise vos données et pourquoi

DispoSP est utilisé par [identité et coordonnées du responsable du traitement] pour recueillir vos disponibilités, préparer et publier les gardes et gérer les désistements. Le traitement repose sur [base légale validée et fondement juridique applicable].

Quelles informations sont concernées

Les données concernent votre identité, vos coordonnées, vos qualifications, vos disponibilités, vos affectations, les désistements et les traces nécessaires au fonctionnement et à la sécurité. Elles sont fournies par vous, par [service source] ou générées par le service. [Préciser les champs obligatoires, facultatifs et les conséquences d'une absence de réponse.] Ne renseignez pas de détail médical ni de donnée inutile concernant un tiers dans les champs libres.

Qui peut les consulter et pendant combien de temps

Les données sont accessibles aux personnels habilités selon leurs fonctions et aux prestataires nécessaires au service : [liste et rôles validés]. Elles sont conservées selon [durées ou critères approuvés par catégorie]. [Préciser les transferts hors EEE, les garanties applicables et le moyen d'en obtenir une copie, ou leur absence après vérification.]

Comment exercer vos droits

Vous pouvez demander l'accès à vos données et leur rectification, ainsi que, dans les conditions prévues par la réglementation, leur effacement, la limitation du traitement et vous y opposer. Adressez votre demande à [contact et coordonnées du DPO ou canal dédié]. Vous pouvez également adresser une réclamation à la CNIL sur www.cnil.fr. [Adapter les droits à la base légale retenue ; préciser la portabilité seulement si elle est applicable.]

[Confirmer l'existence ou l'absence de décision entièrement automatisée au sens du RGPD et compléter les informations requises le cas échéant.]

Références pour finaliser le dossier

- 1 CNIL — Contrats entre responsable du traitement et sous-traitant
- 2 Supabase — Data Processing Addendum
- 3 Resend — Data Processing Addendum
- 4 CNIL — Les durées de conservation des données
- 5 CNIL — Le droit à la portabilité
- 6 CNIL — Informer les personnes
- 7 CNIL — Le rôle du DPO